

3-DAY LIVE SOC WORKSHOP · DAY 3

Live Alert Handling: Investigating a Phishing Incident

From a reported email to a closed ticket — headers, threat intelligence, sandboxing, and a real SIEM investigation, walked through live.

Trinetraa Cyber Academy

QUICK RECAP

Yesterday: Core Attack Concepts

Day 2 got inside the attacker's mindset. Before we investigate a live alert, let's remind ourselves what we're looking for.



Phishing Campaigns

How attackers craft lures — urgency, authority, and familiarity — to get a click or a credential.



Malware Families

What common malware types do once they're on a machine, and how they typically get there.



The Threat Landscape

Who's attacking, why, and where phishing sits as the most common way in.

90%+

of breaches start with a phishing email

3 sec

is often all it takes for one click to matter

1

report from one employee is how today's investigation starts

TODAY

Day 3 Agenda

We go from theory to practice — the exact toolkit and flow a working SOC L1 analyst uses on every reported phishing email.

- 1 Email headers** — what they are, and how to read them
The metadata every investigation starts with
- 2 SPF, DKIM & DMARC** — the three checks that catch spoofing
What "pass" and "fail" actually mean
- 3 Threat intelligence tools** — VirusTotal, AbuseIPDB, MXToolbox
Turning an IP or hash into a verdict
- 4 Sandboxing** — detonating links and attachments safely
Never click or open anything directly
- 5 Live demo** — investigating a real ticket start to finish
TrinetraTicket + TrinetraSIEM, in front of you

Three Kinds of Evidence, One Verdict

Every phishing investigation pulls from the same three sources. No single one is enough on its own — the verdict comes from all three agreeing.



1. The Message Itself

Headers, sender, subject, body. Does the technical metadata match what the email claims to be?



2. External Reputation

Is the sending IP, domain, URL, or file hash already known to be malicious, or has no history at all?



3. What Actually Happened

Inside your own environment — who received it, who clicked, and what happened next.

What Is an Email Header?

Think of it as the envelope, not the letter. The body is what the sender wants you to see. The header is the trail the message actually left behind getting to your inbox.

```
Return-Path: <bounce@some-domain.com>
Received: from mail.some-domain.com (unknown [185.220.101.47])
    by mx.yourcompany.com; Tue, 01 Sep 2026 08:14:20 +0000
Message-ID: <a1f92c3d@some-domain.com>
From: "IT Helpdesk" <it-helpdesk@some-domain.com>
Authentication-Results: spf=fail; dkim=fail; dmarc=fail
```

What to look for

- Does "From" match the "Received" sending server?
- Is the sending IP internal (private) or external?

Real tool

- MXToolbox Email Header Analyzer — paste headers, get a readable breakdown

SPF — Sender Policy Framework

A DNS record listing exactly which mail servers are allowed to send email for a domain. SPF asks one question: was this email sent from a server the domain owner actually authorized?

SPF = PASS

The sending server's IP is on the domain's approved list. This is what you'd expect from genuine mail.

SPF = FAIL

The sending server was **not** authorized by the domain. A strong spoofing indicator — but check DKIM and DMARC too before concluding.

DKIM — DomainKeys Identified Mail

A cryptographic signature attached to the email, verified against a public key published in the sender's DNS. DKIM asks: has this message been altered in transit, and was it really signed by this domain?

DKIM = PASS

The signature is valid — the message genuinely came from a system holding that domain's private signing key.

DKIM = FAIL / NONE

No valid signature. Many phishing kits skip DKIM entirely — a bare `dkim=none` is common on spoofed mail.

DMARC — Domain-based Message Authentication

DMARC doesn't check anything new by itself — it tells receiving servers what to do based on SPF and DKIM, and adds one more critical check: alignment.

Alignment is the key idea

SPF and DKIM can each pass on their own domain, but DMARC requires that domain to actually **match** the visible "From" address the user sees. This is exactly what catches a lookalike domain that technically has valid SPF/DKIM for *itself*.

DMARC = PASS

Authenticated and aligned to the visible sender domain.

DMARC = FAIL

Failed alignment or authentication. Combined with the policy (`p=reject`, `quarantine`, or `none`), this tells you what the mail server was supposed to do about it.

Threat Intelligence Tools

Once you have an IP, domain, URL, or file hash from the headers, take it outside your own systems and ask: has anyone else already seen this?

VirusTotal

Check an IP, domain, URL, or file hash against 70+ antivirus and threat-intel engines at once. The go-to first stop for almost any indicator.

AbuseIPDB

Community-reported abuse history for an IP address — useful for confirming a sending server has a track record of spam or attacks.

MXToolbox

Header analysis plus blacklist checks — is this sending domain or IP listed on any known spam blacklists?

WHOIS Lookup

When was this domain registered? A domain registered days ago is a major red flag for a phishing campaign.

Sandboxing: Never Click Anything Directly

A sandbox is an isolated, disposable environment that opens a link or detonates an attachment for you — so you see exactly what it does, without risking your own machine.



urlscan.io

Submit a URL and see a screenshot of what actually loads, plus every network request it makes — no account needed.



ANY.RUN

Interactive sandbox for files — watch the process tree build live as a malicious attachment executes.



Hybrid Analysis

Automated malware analysis with a detailed behavioral report: files dropped, registry changes, network calls.

What a sandbox report tells you

The process tree (what spawned what), any outbound network connections and to where, files created or modified, and a final verdict score — all without a single click on your own workstation.

Confirming Scope Inside Your Own Environment

Headers and external tools tell you whether an email is *capable* of harm. Only your own logs tell you whether it actually *caused* any.

-  **Who else received it?** Search the sender or subject across your log index — one report is rarely the whole campaign.
-  **Who clicked the link?** Search the URL — and check the HTTP status each person got: 200 means the page was live and rendered, 404 means it was already taken down.
-  **Who opened the attachment?** Search the file hash — did it show up on any other machine, and did anything execute afterward?
-  **Did any account get compromised?** Look for a successful sign-in shortly after, especially from an unusual location or without MFA.

PUTTING IT ALL TOGETHER

The Full Investigation Flow

This is the exact sequence we'll follow live in a few minutes.

- 1 Assign the ticket to yourself
- 2 Read the report and expand the email headers
- 3 Check SPF / DKIM / DMARC, then the sending IP's reputation externally
- 4 Read the subject and body for social-engineering markers
- 5 Sandbox any link externally, then search who received/clicked it internally
- 6 Sandbox any attachment externally, then search its hash internally
- 7 Collect evidence, write notes, and close — or escalate

NOW, LIVE

Let's Investigate a Real Ticket

We'll open a live phishing ticket in TrinetraTicket, follow the seven-step flow together, and close it with real evidence — using TrinetraSIEM to confirm exactly who was affected.

TrinetraTicket + TrinetraSIEM

Key Takeaways

- Headers don't lie the way a message body can — SPF, DKIM, and DMARC are your first, fastest check.
- Never trust one signal alone. A real verdict comes from headers + external reputation + your own logs agreeing.
- Never click a link or open an attachment yourself — sandbox it externally first, every time.
- A dead link (404) doesn't mean the campaign was harmless — check what happened before takedown.
- This exact flow works for every phishing ticket you'll ever see. Practice it until it's automatic.

THANK YOU

That's a Wrap on the Workshop

Want to go deeper? The 6-month SOC Analyst Training Program picks up exactly where this leaves off — five more full phishing investigations, live tool access, and a real incident ticket queue.

trinetraa.in · Questions? Ask now or reach out on WhatsApp